

# Crypto Investigator

## Technical Validation Document

|                         |                                                                                                         |
|-------------------------|---------------------------------------------------------------------------------------------------------|
| Software version        | v1.0.0 (file: VERSION)                                                                                  |
| Document generated      | 2026-09-04 23:45 UTC                                                                                    |
| Generated by            | tools/make_docs.py (part of the audited source)                                                         |
| Complete source listing | docs/listings/v1.0.0-full-listing.txt                                                                   |
| Listing SHA-256         | 58ff09ae340568de66fbb68953d306823ec61e2bf7fbce76e11303fb2a5c3ae1                                        |
| Audience                | Independent technical experts, prosecutors, and courts evaluating the reliability of this tool's output |

## 1. Purpose and scope

This tool follows cryptocurrency from a victim's wallet across public blockchains until the funds reach a custodial service (an exchange or similar business) on which legal process can be served. Its deliverable is a set of exit points - addresses, transaction IDs, timestamps and amounts - packaged with draft records-request language and a complete chain-of-custody log.

**What the tool does not do.** It does not identify natural persons; account-holder identity must come from the custodian's KYC records via subpoena or warrant. It does not 'demix' mixing services, guess at continuity across privacy tools, or produce risk scores. It uses only public data, and it never presents an inference as a fact: every attribution and heuristic carries a stated confidence level and basis.

## 2. Design principles

- **Facts are separated from inferences.** On-chain transactions (IDs, amounts, timestamps) are reported as facts. Roles, attributions and classifications are inferences, each carrying a confidence level (HIGH / MEDIUM / LOW) and a written basis stating its source.
- **Dead ends are reported honestly.** Mixers, smart contracts, privacy coins and unlabelled busy services stop the trace and are flagged as such. The tool never fabricates continuity through an obstacle.
- **Every data acquisition is reproducible.** Each network pull is recorded with its exact request URL, UTC timestamp, HTTP status, and the SHA-256 hash of the raw response body, so any analyst can re-issue the request and compare hashes.
- **Public data only.** All sources are publicly accessible; no proprietary attribution database is used or simulated.
- **Local and offline-safe.** The application binds to 127.0.0.1 only; case data never leaves the machine.

## 3. System architecture

The software is a single-machine Python application (FastAPI web server, SQLite storage, browser-based user interface). No component is exposed to the network; the server listens on 127.0.0.1:8321 (localhost) only.

Modules, each inlined in full in the source listing:

- **app/config.py** - every tunable constant (thresholds, caps, endpoints) in one auditable file; no logic.
- **app/database.py** - SQLite schema and access: cases, traces, settings, labels, the immutable HTTP evidence cache, the chain-of-custody log, and IC3 worksheet drafts.

- **app/providers/** - data acquisition clients (Bitcoin via the Esplora API in pool / keyed / self-hosted modes; Ethereum via Blockscout, Routerscan, Etherscan V2 or Alchemy; Tron via TronGrid) built on a shared base class that enforces cache, throttle, retry, custody logging and per-provider counters for every request (GET and JSON-RPC POST).
- **app/labels/** - attribution store: OFAC SDN parsing, GraphSense TagPack, ScamSniffer and eth-labels importers, the bundled seed list, the agency's own flags, and partner flag packs (export/import with integrity hash).
- **app/intel/** - on-demand Chainabuse lookups (budgeted, cached), plain-language wallet summaries (no AI) and bulk address triage.
- **app/tracing/** - input format detection, the forward/backward tracing engine and Bitcoin common-input clustering.
- **app/prices.py** - USD context values (CoinGecko with keyless Kraken/Coinbase fallbacks).
- **app/report/** - the court-ready trace report, freeze/preservation letters, affidavit and traceroute text, the evidence package, and the IC3 worksheet (PDF generation).
- **app/scheduler.py** - wallet-watch checks and label auto-refresh; **app/secretstore.py** - DPAPI encryption of keys; **app/assistant.py** - the optional AI assistant with its audit log; **app/launcher.py** - the console-free tray launcher.
- **app/ic3.py** - IC3 complaint worksheet data model and trace prefill.
- **app/static/** - the browser interface (plain HTML/JS/CSS; the only third-party component is the bundled Cytoscape.js graph library, served locally).

## 4. Data sources

- **Bitcoin:** the Esplora REST API. Default 'pool' mode rotates <https://mempool.space/api>, <https://blockstream.info/api> and a community host, which serve the identical API; 'keyed' mode uses the Blockstream Explorer API with agency credentials; 'custom' mode uses a single agency-run node. The custody log records the exact host and URL of every pull; immutable records share one evidence-cache entry regardless of host.
- **Ethereum and ERC-20 tokens:** keyless Blockscout (default) or Routerscan; with a free key, Etherscan V2 (<https://api.etherscan.io/v2/api>) or Alchemy (JSON-RPC, including internal transactions); or an agency-run Blockscout. Keys are excluded from logged URLs and cache keys, and Alchemy calls are logged as key-free descriptors, so custody logs are shareable and re-runnable by another analyst using their own key.
- **Tron and TRC-20 tokens:** the official TronGrid API (<https://api.trongrid.io>); keyless at a low rate, a free key raises the limit (sent as a header, never logged).
- **Sanctions attribution:** the official US Treasury OFAC SDN list, downloaded live from <https://www.treasury.gov/ofac/downloads/sdn.xml> and parsed for digital-currency addresses. Imported at HIGH confidence (official government source). Never cached - each refresh records which snapshot (by hash) was used.
- **Exchange / mixer attribution:** GraphSense TagPacks (MIT community packs, hundreds of thousands of addresses, pack provenance and last-modified date on every label), Etherscan public name tags via the MIT eth-labels dataset (Ethereum), and a small bundled seed list. All imported at MEDIUM confidence and marked as community/explorer tags, not official records. Every report states that absence of an exchange label is not evidence of absence.

- **Scam-report corroboration:** the ScamSniffer public drainer blacklist, Etherscan 'Take Action'/exploit tags, and on-demand Chainabuse (TRM Labs) lookups. These are third-party, unverified reports: raised as corroborating findings, never as stopping points or proof.
- **Agency designations:** the agency's own wallet flags (presented everywhere as the agency's own) and partner agencies' flag packs (a separate source, always named as the originating agency's designation; integrity-hashed on import).
- **USD prices (context only):** CoinGecko public API (<https://api.coingecko.com/api/v3>) with keyless Kraken and Coinbase daily-candle fallbacks. Not evidence; see section 8.

## 5. Acquisition integrity (chain of custody)

All network access flows through one code path (app/providers/base.py) that applies, in order:

- **Evidence cache.** Confirmed on-chain data is immutable, so the first captured response for a given request is stored permanently in SQLite (raw bytes + SHA-256) and served from disk thereafter; existing entries are never overwritten. Data that can change (address activity, sanctions list, prices for the current day) is deliberately never cached.
- **Throttling.** A per-source minimum request interval keeps the tool inside free-tier limits (e.g. 0.6s for mempool.space, 3.0s for CoinGecko).
- **Retry.** Rate-limit and server errors back off exponentially up to 4 attempts; a 404 is treated as a definitive answer and logged, not retried.
- **Custody logging.** Every acquisition - live or from cache - is appended to the custody\_log table with: source, the exact re-runnable request URL, HTTP status, SHA-256 of the raw body, whether it was served from the evidence cache, and a UTC timestamp. The full log exports as CSV and appears (up to a size cap) as an appendix in every trace report.

## 6. Tracing algorithm

**6.1 Starting point.** A trace is anchored to the victim's wallet address, confirmed by the investigator.

Optionally, one 'focus transaction' hash restricts direction: only that payment's outputs leaving the victim wallet become the first hop (outputs returning to the victim wallet - change - are excluded). The engine verifies the wallet actually participates in the focus transaction: if the wallet is only a recipient, the trace falls back to the full wallet with a written warning; if the wallet is not in the transaction at all, the trace fails with an explicit error rather than tracing the wrong funds. For a multi-input Bitcoin transaction, outputs are attributed to the payment as a whole and the report says so. In a focus-transaction trace, hops are counted from the FIRST SUSPECT WALLET (the payment's recipient); the focus payment itself is the approach to hop 1.

**6.1a Time-forward rule.** Money cannot flow backward in time: every address in the trace is examined only from the moment the traced funds arrived at it, and movements dated earlier are ignored (their count appears in a written warning). A suspect wallet's unrelated prior history therefore cannot enter the trace.

**6.2 Expansion.** The engine walks breadth-first from the starting point, following outgoing movements hop by hop up to a user-set depth (1-6 hops; default 3). The investigator may instead select EXTENDED mode (with or without a focus transaction): every branch is followed until it resolves into a classified outcome (section 6.6), bounded by 25 hops and the size caps in 6.5. Movements below the dust thresholds (defaults 0.0001 BTC / 0.001 ETH / 1.0 token units, user-adjustable) are not followed. Value accounting is taint-by-touch ('poison'): every qualifying outgoing movement is followed in full; per-unit apportionment (FIFO/haircut) is not applied, and every report states this.

**6.2a Search patterns.** The investigator selects a branch-selection policy per trace, and the report names it: RAPID follows, per address and per asset, the largest outgoing movements covering 80% of the outgoing value (max 3 branches); BALANCED follows movements carrying at least 5% of the outgoing value (max 8

branches); THOROUGH follows every movement above the dust threshold. Selective search is never presented as complete search: every skipped branch is counted (with per-asset value totals) in a written notice, itemised in the JSON export, and the affected addresses are flagged. The intended workflow is Rapid/Balanced to locate the custodian quickly, then a Thorough re-trace for the complete court record.

**6.3 Movement semantics.** Bitcoin: for each transaction where the traced address appears in an input, each output is a movement; outputs paying the traced address itself are treated as change and excluded; non-standard outputs (e.g. OP\_RETURN) have no destination address and are skipped. Ethereum: native ETH transfers plus ERC-20 token transfers sent from the traced address, newest first; reverted transactions and zero-value contract calls are skipped; token amounts use the token's reported decimals, with USDT/USDC handled by vetted constants.

**6.4 Classification.** Before an address is expanded it is classified, in this priority order, and stopping roles are not expanded further: (1) OFAC-sanctioned (official list, HIGH confidence); (2) labelled mixing service - flagged 'trail obscured', never guessed through; (3) labelled exchange - recorded as an EXIT POINT, the deliverable; (4) smart contract (Ethereum) - flagged, not followed; (5) high-activity heuristic - an address with more than 500 transactions is treated as a probable service and not expanded (explicitly labelled a LOW-confidence heuristic); otherwise (6) intermediary pass-through. Exit detection also runs the moment an edge lands on a labelled exchange, so exits at the depth limit are still captured.

**6.5 Safety caps (all reported when hit).** Per address, only the most recent 25 outgoing transactions are followed; a trace is capped at 400 addresses and 1500 movements. When any cap or the depth limit stops exploration, the affected addresses are marked 'unexpanded / trail edge' in the map, the report and the warnings - the tool records where it stopped looking.

## 6a. Outcome classification and findings

Reaching a labelled exchange is not the only useful ending, so every branch ending is classified into an investigative outcome and reported: NAMED EXCHANGE (serve process); FUNDS AT REST (an address that received traced funds and shows no onward movement as of the trace time - a freeze/seizure/monitoring candidate); PROBABLE EXCHANGE DEPOSIT (a heuristic, stated as such: an address that forwarded at least 90% of its traced inflow within 72 hours into a high-activity wallet - the classic deposit-address fingerprint); UNIDENTIFIED BUSY SERVICE (probably nameable via public block-explorer tags); CONSOLIDATION POINT (two or more traced branches merging - a collection wallet, useful for linking victims); OFAC-SANCTIONED or MIXER contact; contact with a wallet FLAGGED BY THIS AGENCY (cross-case link) or FLAGGED BY A PARTNER AGENCY (imported pack, named as that agency's designation); contact with a PUBLICLY REPORTED SCAM ADDRESS (corroboration, not proof); a Bitcoin ADDRESS CLUSTER (several traced addresses presumed one wallet under the common-input-ownership heuristic, CoinJoin-like transactions excluded, evidencing transactions listed, MEDIUM or LOW confidence); and UNRESOLVED TRAIL EDGES (re-trace candidates). Each finding carries the underlying facts, its heuristic basis where applicable, and a recommended next step.

A DISPOSITION OF FUNDS table accounts for the traced value arriving at every terminal bucket, including an explicit 'not examined' bucket totalling what the dust threshold and search pattern skipped. Because accounting is taint-by-touch, terminal amounts can include co-mingled third-party funds, and the report says so.

## 7. Attribution and confidence model

Attribution labels live in one table with their source and confidence, and reports print both. The tiers are:

- **HIGH** - official source (US Treasury OFAC SDN list) or multiple corroborating sources.
- **MEDIUM** - a single reputable public/community source (e.g. a block-explorer entity tag); unverified.

- **LOW** - a heuristic inference produced by this tool's own analysis (e.g. the high-activity flag).

A role assigned during tracing (victim, intermediary, exchange, sanctioned, mixer, contract, high-activity, unexpanded) is an analytical inference; each node's written basis states exactly why it was assigned, and the report's address table reproduces these bases verbatim.

**Compliance designations.** Identified exchanges may additionally carry a COMPLIANT / NON-COMPLIANT designation from a locally stored, agency-editable list (data/labels/exchange\_compliance.json), used to guide legal-process strategy (cooperative custodian vs. MLAT or alternatives). Every surface that shows the designation states its provenance: it is the investigating agency's own designation made with reference to FATF (Financial Action Task Force) guidance - NOT an official FATF publication, as FATF evaluates jurisdictions rather than individual businesses.

## 8. USD valuation (context, not evidence)

Movements in BTC and ETH are annotated with an approximate USD value computed from CoinGecko's daily price for the transaction's UTC date; USDT and USDC are valued at \$1.00 by the peg; all other tokens are left unvalued rather than guessed. Intraday movement is not captured. Every surface that shows a USD figure labels it an estimate, and the report's methodology section repeats the limitation. Price requests go through the same custody-logged pipeline as blockchain data; past dates are immutable and cached, the current day is not. A price-source outage degrades the trace to crypto-only amounts with a warning - it can never change or fail a trace. The live ticker in the interface is display-only and stored nowhere.

## 9. Outputs

- **Trace report (PDF)** - case summary; ranked exit points with funding transactions; DRAFT records-request language per custodian (marked for counsel review); address table with role bases; complete transaction table; methodology and limitations; chain-of-custody appendix.
- **Chain-of-custody log (CSV)** - every acquisition for the trace, complete and machine-readable.
- **Raw trace result (JSON)** - the full graph, exits and warnings for interoperability and archival.
- **Fund-flow traceroute** - for every exit, a hop-by-hop path from the victim wallet to the exchange deposit address (addresses, amounts, USD estimates, transaction IDs, UTC times), printed in the report and exportable as plain text for quotation in a search warrant or affidavit.
- **IC3 complaint worksheet (PDF)** - mirrors the section order and field labels of the official FBI complaint form at [complaint.ic3.gov](https://complaint.ic3.gov), prefilled from trace data where possible. IC3 offers no electronic submission; the worksheet is transcribed by a person, and the tool says so.
- **Freeze / preservation request letters (PDF, DRAFT-watermarked)** - per receiving address, with the funding transactions as Attachment A, addressed to the attributed custodian or, for traced USDT/USDC at an unattributed wallet, to the token issuer; counsel review required before service.
- **Affidavit methodology draft (text)** - numbered paragraphs describing sources, method, scope, attribution framework, records integrity and (when applied) clustering.
- **Evidence package (ZIP)** - all of the above for one trace plus a manifest listing the SHA-256 of every packaged file.
- **Map image (PNG), bulk-triage table (CSV), case export (JSON) and flag pack (JSON, hashed).**

## 10. Visualization integrity

The money-flow map offers readability aids: runs of one-in/one-out pass-through addresses collapse into a single dashed edge, multiple deposit addresses of one exchange group into an entity node, and sprays of

small dead-end branches fold into a counted stub. These are display operations only. The underlying result - every address, movement, amount and hash - is unaffected: collapsed elements list their full contents when clicked, an 'Expand all' control shows every address individually, and the PDF, CSV and JSON exports always contain the complete data regardless of the display state.

## 11. Known limitations

Each release ships a changelog (CHANGELOG.md) whose 'known limitations' sections are part of this validation record. Material limitations as of this version:

- Only the most recent 25 outgoing transactions per address are examined; heavy later activity can conceal an older spend (a date-window filter is roadmapped).
- Bitcoin clustering uses only the common-input-ownership heuristic over the transactions the trace parsed; change outputs to fresh addresses are otherwise followed like any other movement, and clusters are inferences with known failure modes (CoinJoin, custodial batching).
- Funds entering smart contracts (swaps, bridges, mixers) are flagged and not traversed; no continuity is invented.
- Exchange attribution comes from public community/explorer packs; per-customer deposit addresses are unlisted, so absence of an exit finding is not evidence of absence.
- USD figures are daily-price approximations (section 8).
- API keys are encrypted at rest with Windows DPAPI (user-scoped); disk encryption on the evidence machine is still recommended for the case database itself.
- Monero and Litecoin inputs are recognised and explained but not traceable in this version (Monero is not traceable on-chain by design). Tron focus transactions are not supported.
- Third-party scam reports and partner flags are unverified corroboration; the tool labels them so and never treats them as stopping points.

## 12. Verification procedures for reviewers

**12.1 Identify the software.** The version is in the VERSION file and on every report. The complete source of this version is inlined in a single file, docs/listings/v1.0.0-full-listing.txt, whose SHA-256 appears on page 1 of this document. Comparing that hash validates that the code under review is the code that produced the output.

**12.2 Reproduce any data pull.** Take any row of a trace's custody log, re-issue the recorded URL (for Etherscan rows, append your own free API key), hash the response body with SHA-256 and compare. Confirmed historical records (a transaction by ID) are immutable and must match exactly; address-level endpoints append new activity over time, which is why the log records the acquisition timestamp.

**12.3 Reproduce a trace.** Given the report's victim wallet, focus transaction (if any), depth and dust parameters - all printed in the case summary - an independent installation of the same version will fetch the same underlying records and reach the same exit points, subject to label-list currency (the OFAC snapshot used is hash-logged).

**12.4 Inspect the evidence store.** All data lives in data/investigator.db, a standard SQLite database openable with any SQLite tool. The http\_cache table holds the raw response bytes exactly as received, alongside their hashes.

**12.5 Examine the code.** The application is small by design (~a few thousand lines, no build step, dependencies pinned in requirements.txt: fastapi, uvicorn, httpx, reportlab). Every constant that affects tracing behaviour is in app/config.py. This document is itself generated by tools/make\_docs.py from those constants,

and both are part of the hashed source listing.

End of technical validation document for Crypto Investigator v1.0.0, generated 2026-09-04 23:45 UTC.